TechBiz Academy

MARYAM REHAN

INTERNSHIP REPORT WEEK 01

CYBER SECURITY (SOC)

Objective

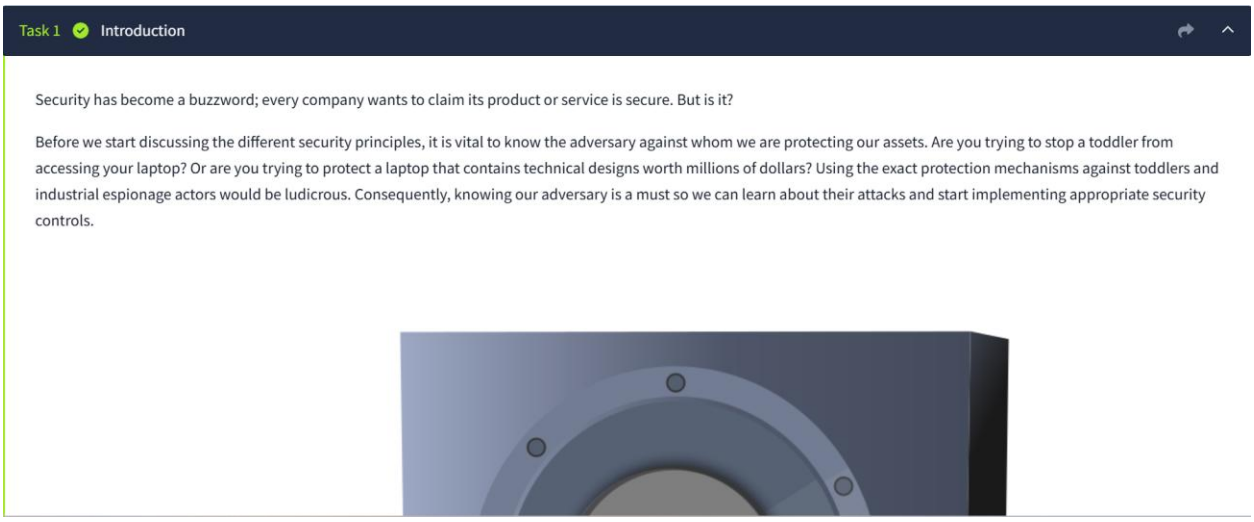
The objective of this task was to understand the fundamentals of cybersecurity, including the CIA Triad, threats, vulnerabilities, and risks. It also aimed to explain the purpose of a Security Operations Center (SOC), understand the responsibilities of L1, L2, and L3 SOC analysts, and identify the key differences between Blue Team and Red Team operations.

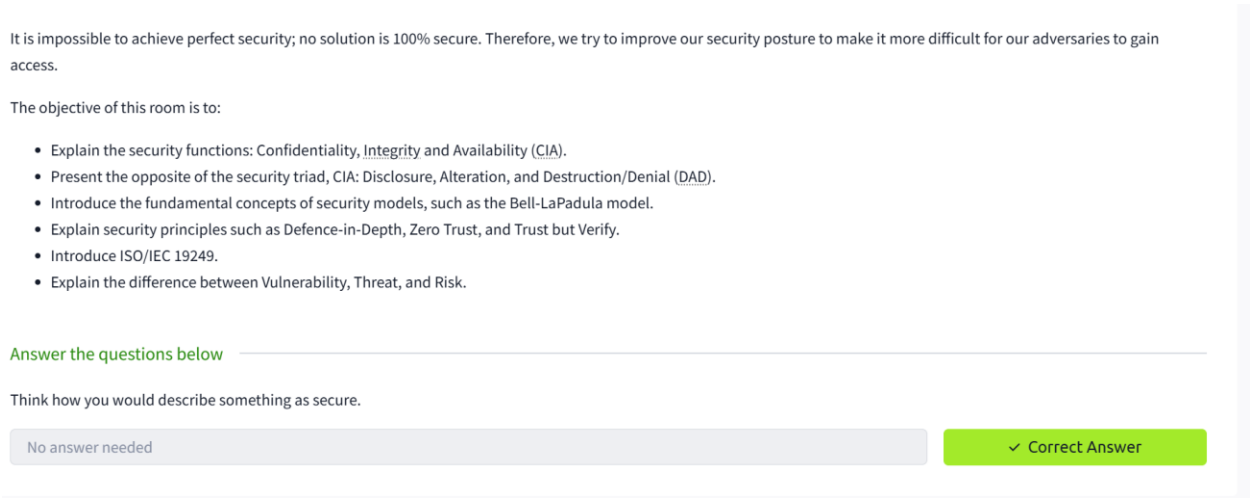
Task : Introduction to Security Principles

Objective: To understand the importance of identifying potential adversaries before selecting security controls.

Learning: Security means protecting assets against unauthorized access, misuse, modification, and damage. Security requirements depend on the type of adversary and the value of the asset being protected. No system is 100% secure; therefore, appropriate security controls are used to reduce risks and strengthen protection.

Platform: TryHackMe Security Principles room





Task 2: CIA Triad — Practical Activity

Objective: To understand the three core security principles: Confidentiality, Integrity, and Availability.

Practical Description: I opened the Security Principles interactive activity on TryHackMe and reviewed the scenario-based questions.

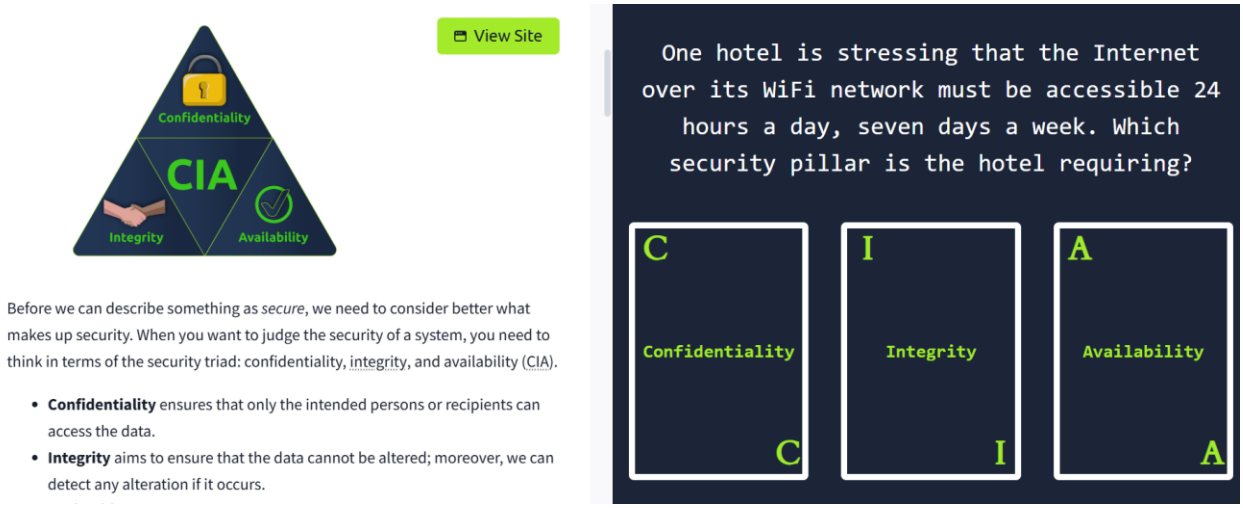
Question 1: During a mission, troops were instructed not to share their location with anyone.

Correct Answer: Confidentiality.

Explanation: Confidentiality ensures that sensitive information is accessible only to authorized people. Keeping the troops' location secret protects sensitive operational information.

Platform: TryHackMe — Security Principles, Task 2 (CIA).

Result:



Task 3: DAD Triad

Objective: To understand the opposite of the CIA Triad and identify common security attacks.

Practical Work: I studied the three components of the DAD Triad: Disclosure, Alteration, and Destruction/Denial. I answered the scenario-based questions on TryHackMe.

Question 1: An attacker accessed customer records and published them online.

Answer: Disclosure — confidential information was exposed to unauthorized people.

Question 2: Attackers switched off the main and backup power supplies, causing the network to shut down.

Answer: Destruction/Denial — the network became unavailable.

Result: Task 3 completed. Both scenarios were identified using the DAD Triad principles.

Platform: Tryhackme





availability.

Protecting confidentiality and integrity to an extreme can restrict availability, and increasing availability to an extreme can result in losing confidentiality and integrity. Good security principles implementation requires a balance between the three.

Answer the questions below

The attacker managed to gain access to customer records and dumped them online. What is this attack?

Disclosure ✓ Correct Answer

A group of attackers were able to locate both the main and the backup power supply systems and switch them off. As a result, the whole network was shut down. What is this attack?

Destruction/Denial ✓ Correct Answer

Task 4: Fundamental Concepts of Security Models

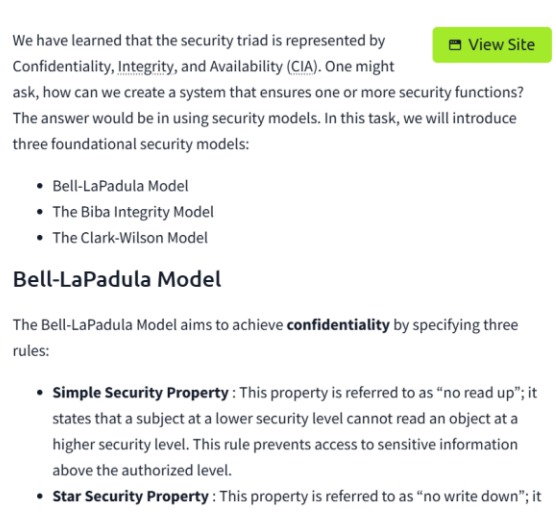
Objective: To understand security models used to protect confidentiality and integrity.

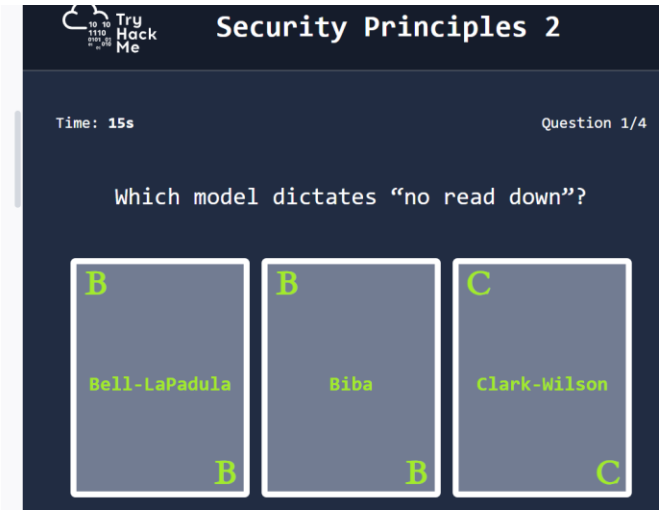
Learning and Practical Work:

- **Bell-LaPadula Model:** Protects confidentiality through rules such as “no read up” and “no write down.”
- **Biba Model:** Protects integrity through rules such as “no read down” and “no write up.”
- **Clark-Wilson Model:** Maintains data integrity through controlled procedures and integrity verification.

Result: Studied three foundational security models and their role in protecting information systems.

Platform: Tryhackme





Task 5: Defence-in-Depth

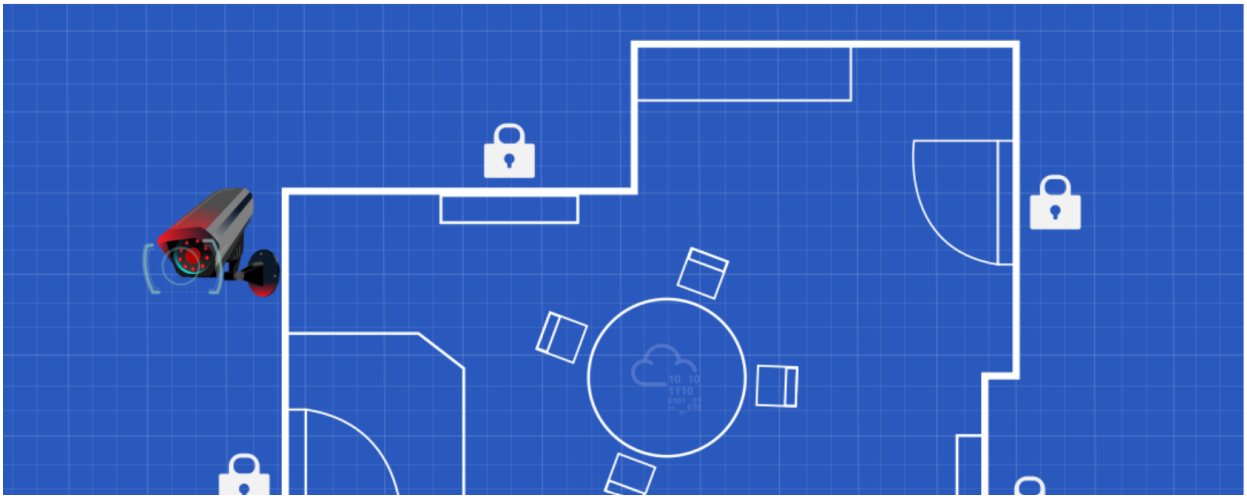
Objective: To understand the importance of multiple layers of security.

Learning: Defence-in-Depth is a security strategy that uses multiple protective layers to reduce the chance of unauthorized access. Examples include locks, access controls, firewalls, authentication systems, and security cameras.

Result: Learned how multiple security layers work together to protect information and systems.

Platform: TryHackMe

Defence-in-Depth



Defence-in-Depth refers to creating a security system of multiple levels; hence it is also called Multi-Level Security.

Consider the following analogy: you have a locked drawer where you keep your important documents and pricey stuff. The drawer is locked; however, do you want this drawer lock to be the only thing standing between a thief and your expensive items? If we think of multi-level security, we would prefer that the drawer be locked, the relevant room be locked, the main door of the apartment be locked, the building gate be locked, and you might even want to throw in a few security cameras along the way. Although these multiple levels of security cannot stop every thief, they would block most of them and slow down the others.

Answer the questions below

Make sure you have read the above.

No answer needed

Check

Task 6: ISO/IEC 19249 Security Principles

Objective: To understand international security principles for designing secure systems and applications.

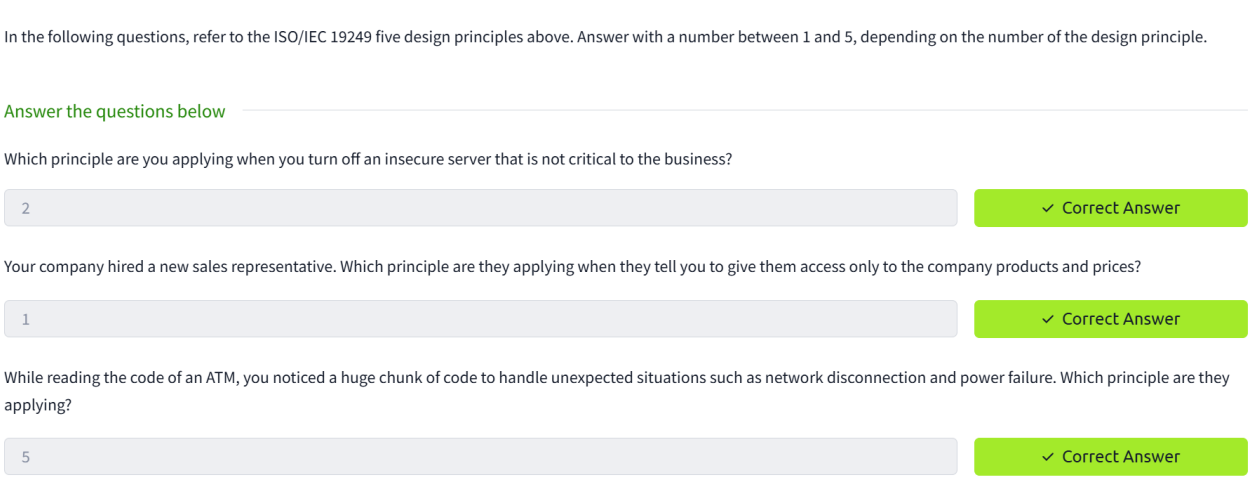
Learning: Studied five architectural principles: Domain Separation, Layering, Encapsulation, Redundancy, and Virtualization. Also learned five design principles, including Least Privilege, Attack Surface Minimisation, Centralized Parameter Validation, Centralized General Security Services, and Preparing for Error and Exception Handling.

Practical Questions and Answers:

1. Turning off an unnecessary insecure server — **2: Attack Surface Minimisation**
2. Giving a sales representative access only to required products and prices — **1: Least Privilege**
3. Handling ATM errors such as network disconnection and power failure — **5: Preparing for Error and Exception Handling**

Result: Learned how security principles help minimize vulnerabilities, limit permissions, and handle unexpected system failures.

Platform: TryHackMe



Task 7: Zero Trust versus Trust but Verify

Objective: To understand two security principles related to trust.

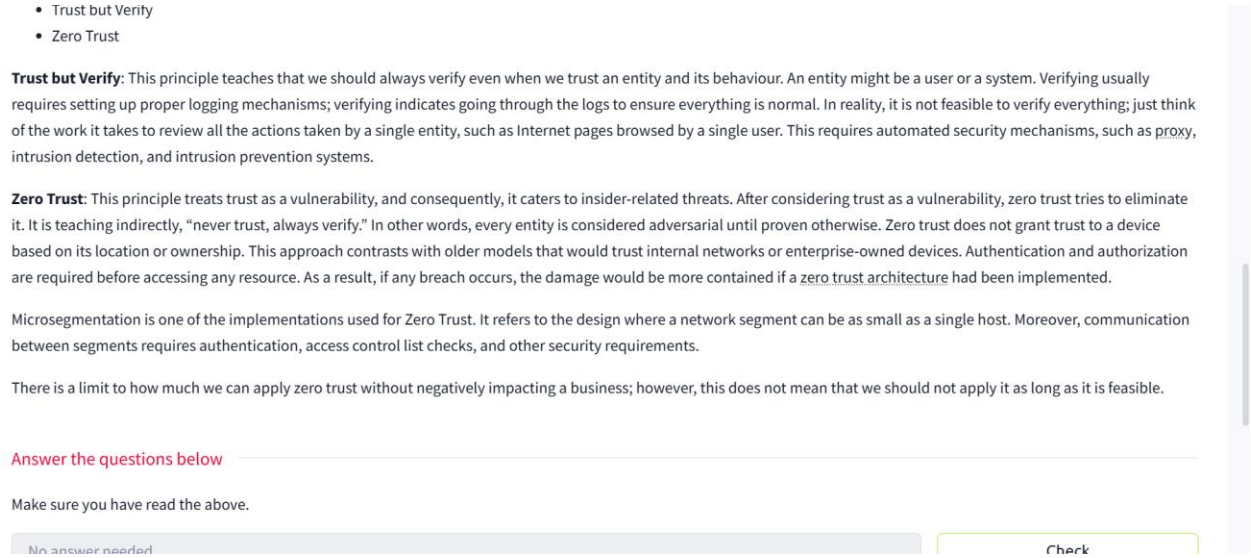
Learning:

- **Trust but Verify:** Even trusted users and systems should be monitored and verified through logs and security tools.

- **Zero Trust:** Never trust automatically; verify every access request through authentication and authorization.
- **Microsegmentation:** Divides a network into small segments to limit unauthorized access and contain security breaches.

Result: Learned how continuous verification and restricted access help protect systems against internal and external threats.

Platform: TryHackMe



- Trust but Verity
- Zero Trust

Trust but Verify: This principle teaches that we should always verify even when we trust an entity and its behaviour. An entity might be a user or a system. Verifying usually requires setting up proper logging mechanisms; verifying indicates going through the logs to ensure everything is normal. In reality, it is not feasible to verify everything; just think of the work it takes to review all the actions taken by a single entity, such as Internet pages browsed by a single user. This requires automated security mechanisms, such as proxy, intrusion detection, and intrusion prevention systems.

Zero Trust: This principle treats trust as a vulnerability, and consequently, it caters to insider-related threats. After considering trust as a vulnerability, zero trust tries to eliminate it. It is teaching indirectly, "never trust, always verify." In other words, every entity is considered adversarial until proven otherwise. Zero trust does not grant trust to a device based on its location or ownership. This approach contrasts with older models that would trust internal networks or enterprise-owned devices. Authentication and authorization are required before accessing any resource. As a result, if any breach occurs, the damage would be more contained if a zero trust architecture had been implemented.

Microsegmentation is one of the implementations used for Zero Trust. It refers to the design where a network segment can be as small as a single host. Moreover, communication between segments requires authentication, access control list checks, and other security requirements.

There is a limit to how much we can apply zero trust without negatively impacting a business; however, this does not mean that we should not apply it as long as it is feasible.

Answer the questions below

Make sure you have read the above.

No answer needed

Check

Task 8: Threat versus Risk

Objective: To understand the difference between vulnerability, threat, and risk in cybersecurity.

Learning:

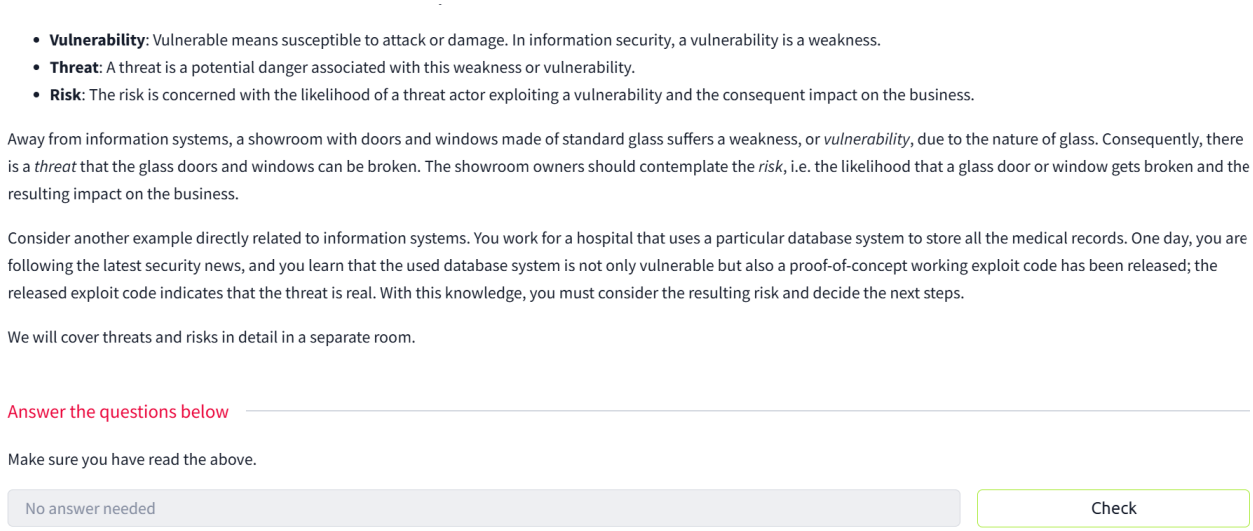
- **Vulnerability:** A weakness in a system that an attacker could exploit.
- **Threat:** A potential danger that could exploit a vulnerability and cause harm.
- **Risk:** The likelihood of a threat exploiting a vulnerability and the potential impact on the business.

Example: A hospital database with a known vulnerability may be targeted by attackers. The vulnerability is the weakness, the threat is the potential attack, and

the risk depends on the likelihood of exploitation and its impact on patient records and hospital operations.

Result: Learned to distinguish vulnerabilities, threats, and risks and understand why organizations must assess and reduce security risks.

Platform: TryHackMe



Task 9: Conclusion

Objective: To review the key concepts and principles learned in the Security Principles room.

Learning: Reviewed the CIA Triad, DAD Triad, authenticity, repudiation, vulnerability, threat, risk, security models, ISO/IEC 19249, Defence-in-Depth, Trust but Verify, Zero Trust, and the Shared Responsibility Model.

Cloud Security: Learned that cloud security responsibilities are shared between the cloud service provider and the customer. Responsibilities vary according to the service model, such as IaaS and SaaS.

Result: Gained foundational knowledge of cybersecurity principles, security models, risk assessment, and cloud security responsibilities.

Platform: TryHackMe

This room covered various principles and concepts related to security. By now, you should be very familiar with CIA and DAD and other terms such as authenticity, repudiation, vulnerability, threat, and risk. We visited three security models and the ISO/IEC 19249. We have covered different security principles such as defence in depth, trust but verify, and zero trust.

Finally, the Shared Responsibility Model is worth mentioning, especially with the increased reliance on cloud services. Various aspects are required to ensure proper security. They include hardware, network infrastructure, operating systems, applications, etc. However, customers using cloud services have different access levels depending on the cloud services they use. For example, an Infrastructure as a Service (IaaS) user has complete control (and responsibility) over the operating system.

On the other hand, a Software as a Service (SaaS) user has no direct access to the underlying operating system. Consequently, achieving security in a cloud environment necessitates both the cloud service provider and the user to do their parts. The Shared Responsibility Model is a cloud security framework to ensure that each party is aware of its responsibility.

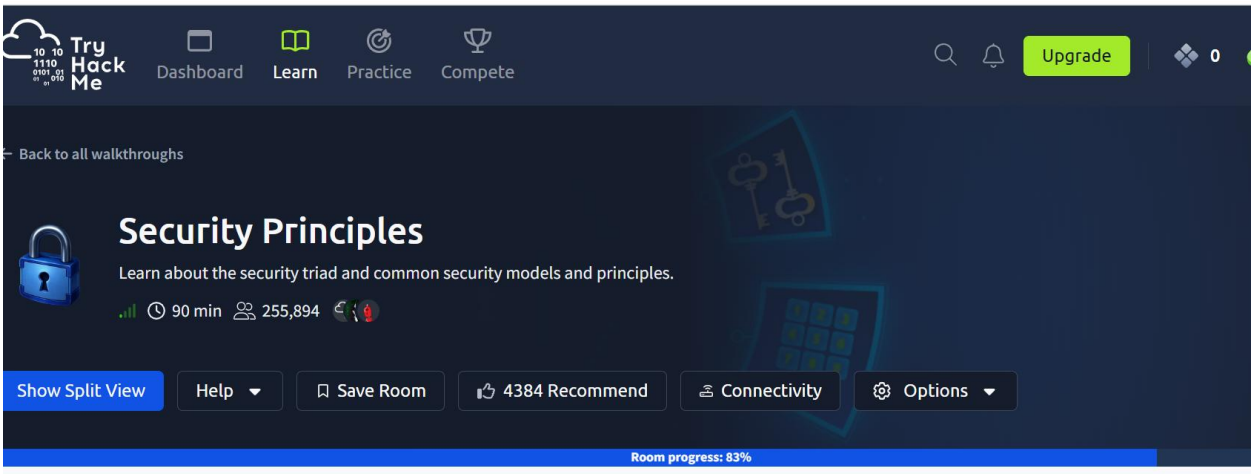
Having finished the Security Principles room, you may proceed to the Intro to Cryptography room.

Answer the questions below

Make sure you have taken notes of all the key terms and acronyms we covered in this room.

No answer needed

Check



Task : Introduction to Penetration Testing

Objective

To understand the role of a penetration tester, the importance of cybersecurity, and the purpose of penetration testing in identifying security weaknesses.

Introduction

Cybersecurity is essential for protecting personal information, computer systems, networks, and organizational data from cyber threats. As cyberattacks and data breaches continue to affect individuals and businesses, organizations need to assess and strengthen their security measures.

A penetration test, also known as a pentest, is an authorized security assessment in which a tester examines an application, system, or network to identify vulnerabilities. It uses techniques similar to those used by malicious attackers but is performed with proper permission and a defined scope.

Responsibilities of a Penetration Tester

- Identify security vulnerabilities in systems, applications, and networks.
- Assess the potential impact of discovered weaknesses.
- Conduct security tests within the authorized scope.
- Document findings and provide evidence.
- Recommend measures to reduce security risks.

Importance of Penetration Testing

Penetration testing helps organizations understand their security weaknesses before malicious attackers can exploit them. It supports risk reduction, improves security controls, and helps protect sensitive information.

Conclusion

This task introduced the fundamentals of penetration testing and explained its role in cybersecurity. I learned that penetration testing must be performed ethically, with proper authorization, and with the aim of improving security.



Task 2: Ethics and Legality in Penetration Testing

Description

This task explains the legal and ethical responsibilities of penetration testers. A penetration test is an authorised assessment of a computer system's security. Before testing begins, the tester and the system owner agree on the permission, scope, and rules of the engagement. Any activity outside the agreed scope may be considered unauthorised.

Types of Hackers

- **White Hat Hacker:** Works legally with permission to identify vulnerabilities and improve security.
- **Grey Hat Hacker:** May identify security weaknesses without permission, even if their intention is to help others.
- **Black Hat Hacker:** Performs malicious or unauthorised activities, such as stealing data or damaging systems, often for personal or financial gain.

Rules of Engagement (ROE)

The Rules of Engagement document defines how a penetration test must be conducted. It contains three main sections:

1. **Permission:** Provides formal authorisation to conduct the test.
2. **Test Scope:** Identifies the systems, applications, and targets included in the assessment.
3. **Rules:** Specifies the techniques allowed or prohibited during testing.

Answers to the Task Questions

1. Authorised security audit — **White Hat**
2. Attacking an organisation and stealing its data — **Black Hat**

3. Document defining how the penetration test is conducted — **Rules of Engagement (ROE)**

Conclusion

This task helped me understand that penetration testing must be performed with proper authorisation and within an agreed scope. Ethical conduct and clear Rules of Engagement help protect both the organisation and the penetration tester.

ask 3: Penetration Testing Methodologies

Objective

To understand the main stages of a penetration test and learn about commonly used cybersecurity testing frameworks.

Description

A penetration testing methodology is a structured approach used to assess the security of systems, networks, and applications. The appropriate methodology depends on the target and objectives of the engagement.

Stages of Penetration Testing

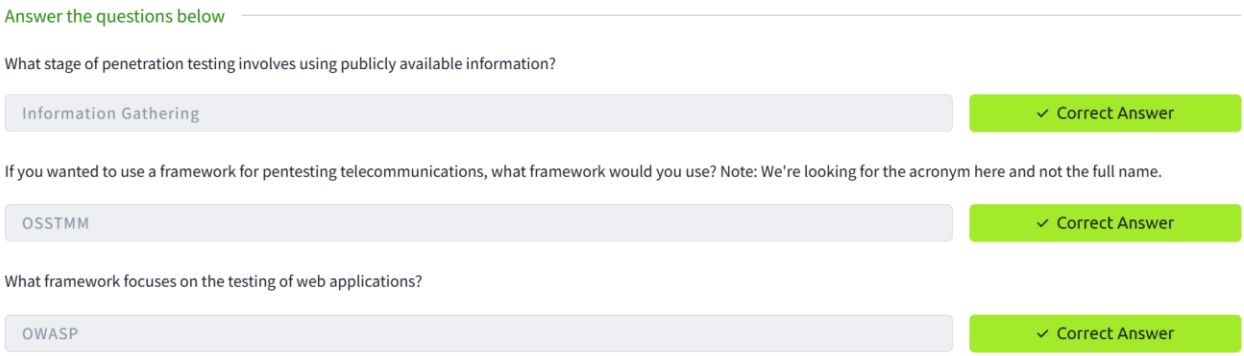
1. **Information Gathering:** Collecting publicly available information about the target through research and OSINT.
2. **Enumeration and Scanning:** Identifying active hosts, open ports, applications, and running services.
3. **Exploitation:** Testing discovered vulnerabilities in an authorised environment.
4. **Privilege Escalation:** Assessing whether access can be expanded to higher privileges.
5. **Post-Exploitation:** Evaluating the impact of access, documenting findings, and preparing the report.

Common Testing Frameworks

- **OSSTMM:** Provides a methodology for testing communications, wired networks, wireless systems, and other security aspects.
- **OWASP:** Focuses on web application security testing and provides guidance for identifying and addressing common vulnerabilities.
- **NIST Cybersecurity Framework:** Helps organisations manage cybersecurity risks and improve their security practices.
- **NCSC Cyber Assessment Framework (CAF):** Helps assess cyber resilience and security controls, particularly for important services and infrastructure.

Conclusion

This task helped me understand the major stages of penetration testing and the purpose of different security frameworks. Selecting a suitable methodology helps ensure that testing is systematic, relevant, and aligned with the authorised scope.



Task 4: Testing Scopes

Objective

To understand the three primary testing scopes used in application security assessments: Black-Box, Grey-Box, and White-Box Testing.

Description

1. Black-Box Testing

Black-Box Testing is performed without access to the application's source code or internal implementation details. The tester interacts with the application as a regular user and examines its functionality and externally visible behaviour.

2. Grey-Box Testing

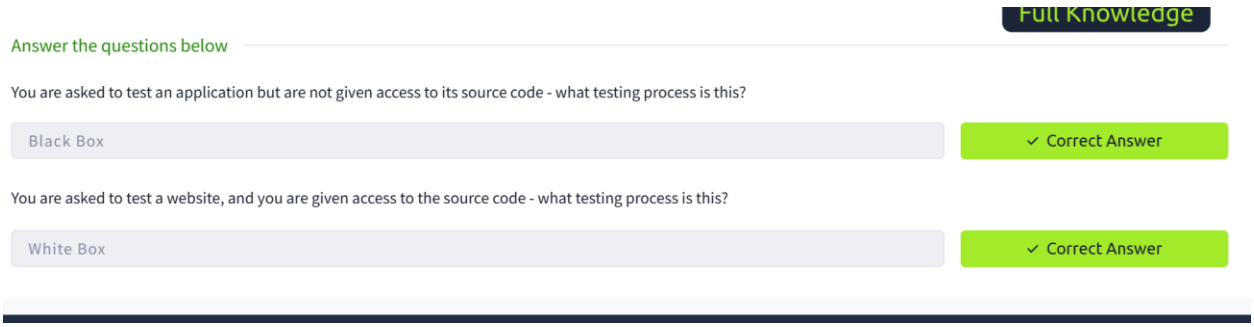
Grey-Box Testing combines elements of Black-Box and White-Box Testing. The tester receives limited information about the application's internal components, which can help make the assessment more efficient.

3. White-Box Testing

White-Box Testing is performed with access to the application's source code and internal design. It allows the tester to examine application logic and validate security weaknesses in greater detail.

Conclusion

This task helped me understand how the amount of information available about an application determines the testing approach. Black-Box Testing uses no internal knowledge, Grey-Box Testing uses limited knowledge, and White-Box Testing uses detailed internal knowledge.



Task 5: ACME Penetration Testing Engagement

Objective

The objective of this task was to complete a guided penetration testing engagement on TryHackMe and understand the importance of following the correct penetration testing process.

Introduction

In this task, I completed a simulated penetration testing engagement for the fictional organisation ACME. The activity demonstrated how penetration testers follow authorised procedures, gather publicly available information, perform enumeration, and document their findings.

Activities Performed

- Reviewed the Rules of Engagement (RoE), including permission, test scope, and testing rules.
- Gathered publicly available information about the organisation.
- Identified relevant information during the enumeration and scanning stage.
- Reviewed the importance of reporting findings clearly.
- Learned that testing activities should be cleaned up after the engagement.

Key Learning Outcomes

This task helped me understand that penetration testing must be performed with proper authorisation and within the agreed scope. I also learned that documenting findings and cleaning up test-related artefacts are important parts of a professional security assessment.

Result

I completed the guided ACME penetration testing simulation on TryHackMe and used the completion flag provided by the lab to answer the task question.

Conclusion

The activity improved my understanding of the penetration testing lifecycle, including authorisation, information gathering, enumeration, reporting, and cleanup. It also highlighted the importance of ethical conduct and responsible security testing.

Task 5 Practical: ACME Penetration Test

ACME has approached you for an assignment. They want you to carry out the stages of a penetration test on their infrastructure. View the site (by clicking the green button on this task) and follow the guided instructions to complete this exercise.

View Site

Answer the questions below

Complete the penetration test engagement against ACME's infrastructure.

THM{PENTEST_COMPLETE}

✓ Correct Answer



Room completed: 100%

Answer the questions below

You are given permission to perform a security audit on an organisation; what type of hacker would you be?

White Hat

✓ Correct Answer

You attack an organisation and steal their data, what type of hacker would you be?

Black Hat

✓ Correct Answ

What document defines how a penetration testing engagement should be carried out?

Rules of Engagement

✓ Correct Answ

Conclusion

In conclusion, this task improved my understanding of cybersecurity fundamentals and the role of a SOC in protecting an organisation's systems and data through continuous security monitoring and incident detection. I learned about the responsibilities of different SOC analyst levels and the importance of collaboration between Blue Teams and Red Teams. This knowledge provides a foundation for further learning and practical experience in cybersecurity and security operations.